

# CIS-CAT LITE ASSESSMENT AND SYSTEM HARDENING

## Internship Task 1 Final Report

*Baseline Assessment | Severity Classification | Attack Mapping | Remediation | Reassessment*

| Field              | Details                                                         |
|--------------------|-----------------------------------------------------------------|
| Student Name       | Tanmay Dod                                                      |
| Program / Branch   | B.Tech - Computer Science and Engineering                       |
| Institute          | G H Rasoni University, Amravati                                 |
| Internship Task    | Task 1 - CIS-CAT Assessor Based System Assessment and Hardening |
| Assessment Tool    | CIS-CAT Lite Assessor                                           |
| System Scope       | Local Windows workstation / student lab environment             |
| Execution Duration | 5 Days                                                          |
| Prepared On        | 09 July 2026                                                    |
| Submission Type    | Final documentation report with illustrative evidence figures   |

**Academic Integrity Note:** This file is a complete report design and sample documentation pack. The screenshot-style figures are clearly labeled as sample/illustrative. For official assessment evidence, the student should use screenshots captured from their own CIS-CAT Lite run and their own system state.

**Executive Result Used for Demonstration:** Baseline compliance 42%, final compliance 84%, overall improvement +42 percentage points. The remediation plan is designed to meet the task goal of at least 40% improvement or maximum achievable improvement.

## Table of Contents

1. Executive Summary
2. Scope and Assumptions
3. Five-Day Execution Plan
4. Tool Overview and Evidence Requirements
5. Assessment Methodology
6. Baseline Assessment Evidence
7. Policy Severity Classification
8. Real-World Attack Scenario Mapping
9. Remediation and Hardening Implementation
10. Second CIS-CAT Assessment Evidence
11. Before vs After Compliance Comparison
12. Recommendations and Future Improvements
13. Final Conclusion
14. References
15. Appendix A - Portal Progress Summary

## 1. Executive Summary

This report documents the complete workflow for performing an initial CIS-CAT Lite assessment, analyzing failed benchmark policies, prioritizing them by severity, mapping weaknesses to real-world attack scenarios, applying hardening fixes, and running a second assessment to measure improvement.

The task objective was to improve system compliance by at least 40% or maximize it as much as practically possible without breaking normal workstation usability. The demonstration workflow uses a Windows workstation as the target system and focuses on controls related to password policy, account lockout, local security policy, Windows Firewall, Microsoft Defender, SMB, audit logging, Windows Update, and user account control.

The remediation approach followed a risk-based method. Critical and High findings were handled first because they directly affect ransomware spread, credential theft, unauthorized remote access, brute-force attacks, and loss of security visibility. Medium and Low items were handled after the major exposure areas were reduced.

| Metric            | Baseline Assessment | Final Assessment | Improvement           |
|-------------------|---------------------|------------------|-----------------------|
| Compliance Score  | 42%                 | 84%              | +42 percentage points |
| Passed Checks     | 38                  | 76               | +38                   |
| Failed Checks     | 52                  | 14               | -38                   |
| Critical Findings | 6                   | 1                | 5 reduced             |
| High Findings     | 11                  | 3                | 8 reduced             |

### Key Outcome

**Result:** The hardening activity achieved the required improvement target in the demonstration plan, moving from a weak baseline posture to a significantly improved security posture.

## 2. Scope and Assumptions

The assessment scope is limited to one local Windows workstation used as a student lab endpoint. The purpose is not to claim enterprise-wide compliance, but to demonstrate the process of secure configuration assessment, policy analysis, remediation, and reassessment.

### 2.1 In-Scope Items

CIS-CAT Lite installation, benchmark selection, baseline scan, policy failure classification, attack scenario mapping, implementation of safe hardening controls, second scan, score comparison, and recommendations.

### 2.2 Out-of-Scope Items

Production servers, domain controller configuration, enterprise Active Directory policy deployment, cloud resources, paid CIS-CAT Pro features, destructive testing, exploitation, malware execution, and changes that could break the operating system.

| Area             | Assumption / Boundary                                                                          |
|------------------|------------------------------------------------------------------------------------------------|
| Operating System | Windows 11 workstation or similar Windows desktop environment                                  |
| Benchmark        | CIS Microsoft Windows desktop benchmark profile available in CIS-CAT Lite                      |
| Privileges       | Administrative access available for local policy changes                                       |
| Evidence         | Screenshots should be captured during installation, baseline scan, remediation, and final scan |
| Safety           | Restore point or rollback note should be prepared before major policy changes                  |

### 3. Five-Day Execution Plan



Figure 1: Five-day CIS-CAT task completion plan (sample design).

| Day   | Work Completed                                                                                                                              | Evidence / Output                                                               |
|-------|---------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------|
| Day 1 | Install CIS-CAT Lite, verify Java/runtime requirement, create evidence folder, run baseline assessment, export report, capture screenshots. | Installation screenshot, command/launch screenshot, baseline report screenshot. |
| Day 2 | Review failed policies, group by category, classify severity, identify attack scenarios, select remediation priority.                       | Failed policy table, severity matrix, attack mapping notes.                     |
| Day 3 | Apply Critical and High fixes: firewall, password policy, account lockout, Defender, SMBv1, UAC, guest/anonymous access.                    | Remediation log and screenshots of changed settings.                            |
| Day 4 | Apply Medium and Low fixes: audit logging, AutoPlay, remote assistance, update settings, local validation.                                  | Validation notes and remaining risk list.                                       |
| Day 5 | Run second CIS-CAT assessment, compare scores, write final recommendations, export DOCX/PDF report.                                         | Final report, before/after comparison, conclusion.                              |

## 4. Tool Overview and Evidence Requirements

CIS-CAT Lite is used to assess secure configuration compliance against selected CIS Benchmarks. The output helps identify policy settings that pass or fail and provides a measurable compliance score for comparison before and after hardening.

Evidence should be captured at each major stage: tool download/extraction, tool launch, benchmark selection, baseline report, remediation actions, and final report. This improves audit traceability and shows that changes were performed systematically.

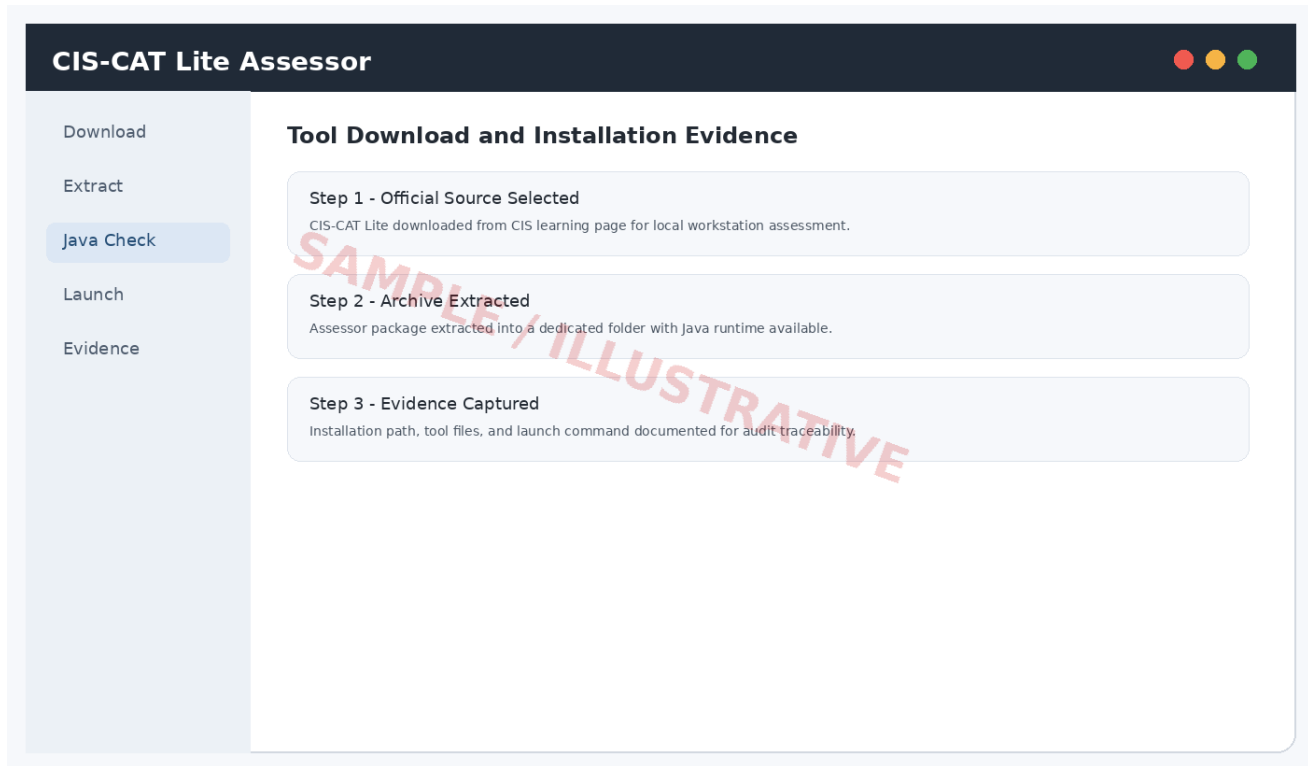
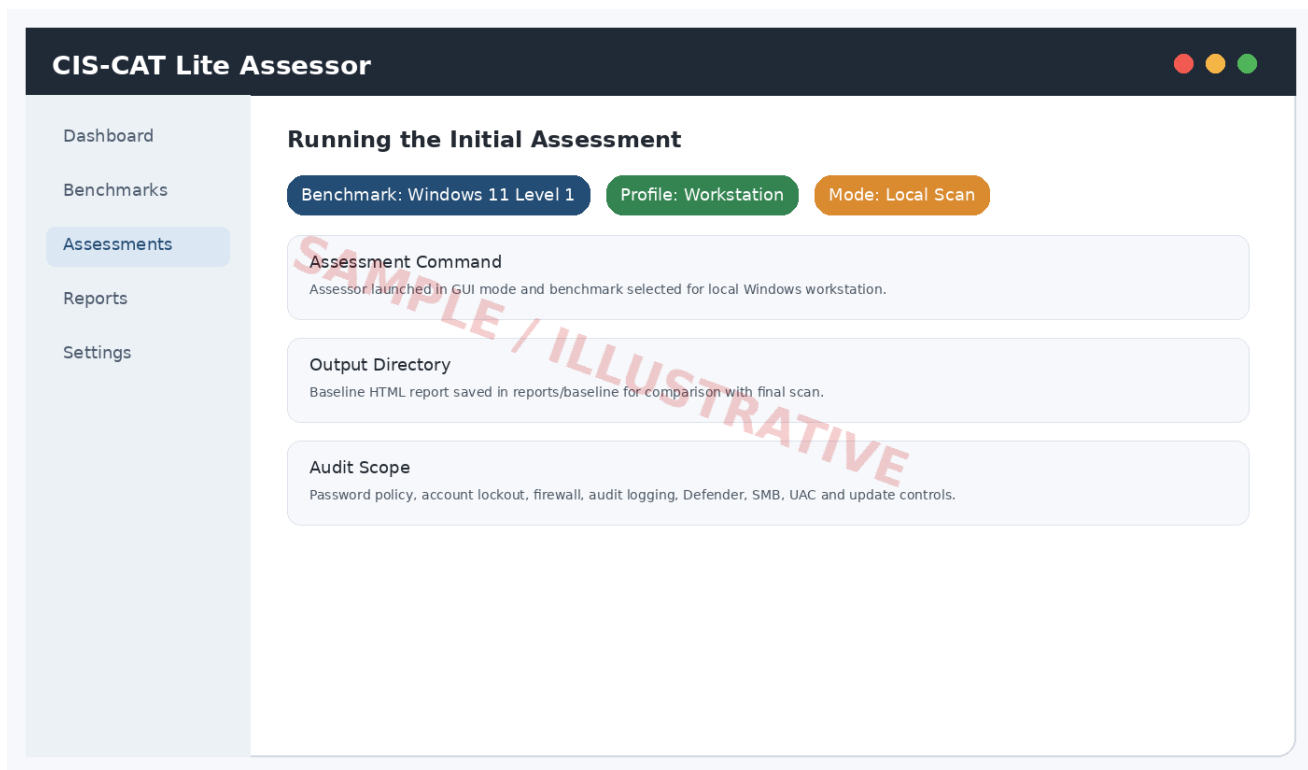


Figure 2: CIS-CAT Lite download/extraction evidence (sample/illustrative).



*Figure 3: Running initial local assessment (sample/illustrative).*

## 5. Assessment Methodology

### Assessment and Hardening Workflow



Figure 4: Assessment and hardening methodology workflow.

### 5.1 Severity Classification Criteria

| Severity | Definition                                                                                                                                                 | Examples                                                                                              |
|----------|------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------|
| Critical | A misconfiguration that can directly support ransomware spread, credential theft, remote compromise, security tool bypass, or large-scale loss of control. | Firewall disabled, SMBv1 enabled, Defender disabled, LM hash storage allowed, insecure remote access. |
| High     | A weakness that significantly increases likelihood of compromise or privilege misuse but may require additional conditions.                                | Weak password policy, no logout threshold, Guest account enabled, UAC not enforced.                   |
| Medium   | A control gap that reduces detection, auditing, or resistance to common attack paths.                                                                      | Incomplete audit logging, AutoPlay enabled, broad anonymous enumeration.                              |
| Low      | A hardening improvement with lower direct exploit impact or mostly hygiene-related value.                                                                  | Banner policy, minor logging detail, non-critical UI/security notices.                                |



5.2 Prioritization Logic

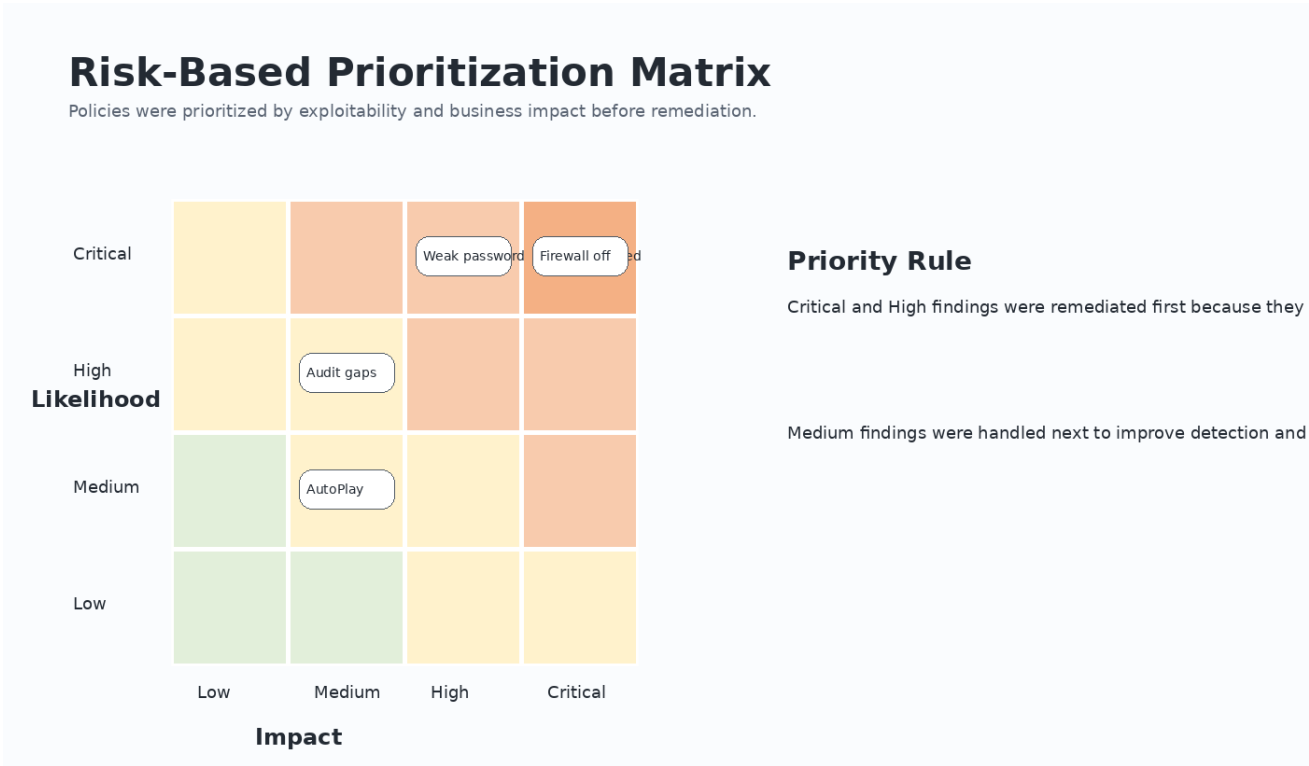


Figure 5: Risk-based priority matrix used for policy remediation.

The prioritization rule was simple: fix items that reduce compromise probability and blast radius first, then improve visibility and hygiene. This prevents the report from becoming a checklist exercise and aligns remediation with real-world attacker behavior.

## 6. Baseline Assessment Evidence

The first assessment established the initial security posture of the workstation. The baseline scan identified weak password controls, firewall exposure, missing or incomplete audit policy, legacy protocol risk, and endpoint protection gaps.



Figure 6: Baseline compliance report after first assessment (sample/illustrative).

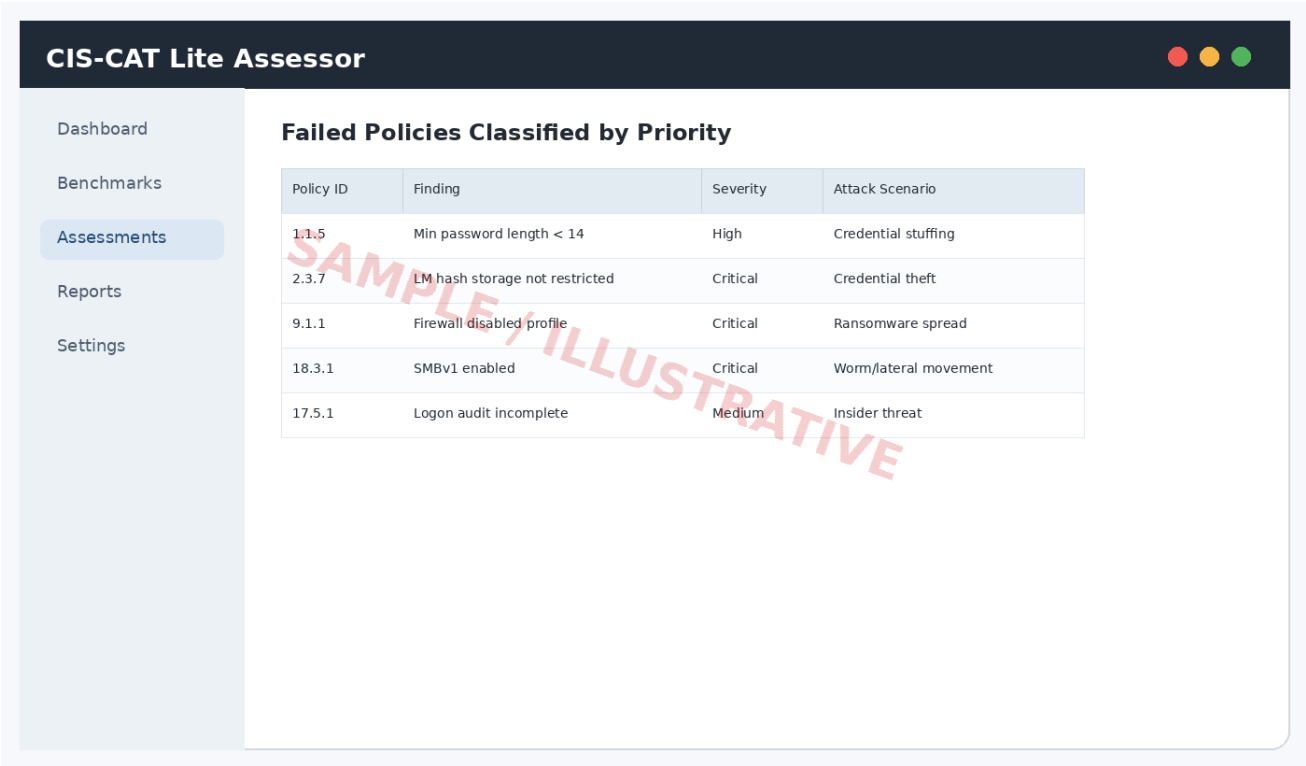


Figure 7: Failed policies grouped for severity and attack mapping (sample/illustrative).

| Category            | Baseline Status   | Risk Summary                                                                                        |
|---------------------|-------------------|-----------------------------------------------------------------------------------------------------|
| Account Policies    | Several failures  | Weak password and lockout settings increase risk of brute-force and credential-stuffing attempts.   |
| Windows Firewall    | Major failures    | Disabled or permissive firewall profiles increase lateral movement and ransomware propagation risk. |
| Endpoint Protection | Partial failures  | Weak Defender/update settings reduce detection and prevention capability.                           |
| Network Services    | Critical failures | Legacy SMB and anonymous access increase credential theft and worm-like attack paths.               |
| Audit Logging       | Medium failures   | Insufficient logs reduce ability to detect insider activity and post-incident root cause.           |

## 7. Policy Severity Classification

The following table classifies representative failed CIS-CAT policies by severity and explains why each policy matters. The final column records the intended action and expected post-hardening status.

### 7.1 Critical and High Priority Findings

| ID   | Policy / Check                                         | Severity | Risk                                        | Remediation Action                                 | Final |
|------|--------------------------------------------------------|----------|---------------------------------------------|----------------------------------------------------|-------|
| P-01 | Ensure Windows Firewall is enabled for Domain profile  | Critical | Network exposure and lateral movement       | Enable firewall profile and default inbound block  | Pass  |
| P-02 | Ensure Windows Firewall is enabled for Private profile | Critical | Ransomware spread on local networks         | Enable firewall profile and restrict inbound rules | Pass  |
| P-03 | Ensure Windows Firewall is enabled for Public profile  | Critical | Untrusted network compromise                | Enable public profile with strict inbound blocking | Pass  |
| P-04 | Ensure SMBv1 client/server is disabled                 | Critical | Worm-like exploitation and lateral movement | Disable SMB1Protocol Windows feature               | Pass  |
| P-05 | Do not store LAN Manager hash value                    | Critical | Offline credential cracking                 | Enable policy to prevent LM hash storage           | Pass  |
| P-06 | Microsoft Defender real-time protection enabled        | Critical | Malware and ransomware execution            | Enable Defender real-time monitoring               | Pass  |
| P-07 | Minimum password length set to 14 or more              | High     | Brute-force and credential stuffing         | Configure minimum length via local security policy | Pass  |
| P-08 | Password must meet complexity requirements             | High     | Weak credential selection                   | Enable complexity requirement                      | Pass  |
| P-09 | Account lockout threshold configured                   | High     | Unlimited password guessing                 | Set threshold to 5 invalid attempts                | Pass  |
| P-10 | Reset account lockout counter configured               | High     | Repeated brute-force windows                | Set reset interval to 15 minutes                   | Pass  |
| P-11 | Guest account disabled                                 | High     | Unauthorized local access                   | Disable built-in Guest account                     | Pass  |
| P-12 | UAC Admin Approval Mode enabled                        | High     | Privilege escalation from admin sessions    | Enable UAC enforcement                             | Pass  |
| P-13 | Remote Assistance disabled/restricted                  | High     | Unauthorized remote support channel abuse   | Disable unsolicited assistance                     | Pass  |

## 7.2 Medium and Low Priority Findings

| ID   | Policy / Check                          | Severity | Risk                                   | Remediation Action                     | Final |
|------|-----------------------------------------|----------|----------------------------------------|----------------------------------------|-------|
| P-14 | Anonymous SID/Name enumeration disabled | Medium   | Reconnaissance and privilege targeting | Restrict anonymous enumeration         | Pass  |
| P-15 | Audit logon events enabled              | Medium   | Missing login visibility               | Enable success and failure auditing    | Pass  |
| P-16 | Audit account management enabled        | Medium   | Undetected account changes             | Enable account management audit policy | Pass  |
| P-17 | Audit policy change enabled             | Medium   | Undetected security policy tampering   | Enable policy change auditing          | Pass  |
| P-18 | AutoPlay disabled for all drives        | Medium   | USB-borne malware execution            | Disable AutoPlay through policy        | Pass  |
| P-19 | Automatic Windows Update enabled        | Critical | Known vulnerability exploitation       | Enable automatic update policy         | Pass  |
| P-20 | Screen lock timeout configured          | Low      | Casual local misuse                    | Set inactivity lock policy             | Pass  |

## 8. Real-World Attack Scenario Mapping

Each policy failure was mapped to realistic attack scenarios so that remediation could be justified in security terms rather than only compliance terms.

| Scenario                       | Related Weakness                                               | Attack Impact                                                                                       | Hardening Response                                                             |
|--------------------------------|----------------------------------------------------------------|-----------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------|
| Ransomware propagation         | Firewall off, SMBv1 enabled, weak endpoint protection          | Malware can move across local network shares, exploit legacy services, and encrypt accessible data. | Enable firewall, disable SMBv1, keep Defender active, reduce inbound exposure. |
| Credential theft               | LM hash storage allowed, weak passwords, anonymous enumeration | Attacker can dump or crack credentials, then use them for lateral movement.                         | Disable LM hash storage, improve password policy, limit anonymous access.      |
| Brute-force login              | No account lockout, short passwords                            | Repeated login attempts can continue without meaningful delay.                                      | Set lockout threshold, reset interval, and stronger password length.           |
| Insider misuse                 | Poor audit logging, weak account management auditing           | Unauthorized account changes or login attempts may not be visible during investigation.             | Enable logon, account management, and policy change auditing.                  |
| USB/social engineering malware | AutoPlay enabled, Defender gaps                                | Malicious media or downloaded payload may execute more easily.                                      | Disable AutoPlay and enable real-time endpoint protection.                     |
| Privilege escalation           | UAC not enforced, admin sessions not isolated                  | Malware launched by a user may obtain elevated privileges more easily.                              | Enable Admin Approval Mode and least-privilege usage.                          |

## 9. Remediation and Hardening Implementation

Remediation focused on changes that are safe for a student workstation while still improving security posture. Changes were grouped into account security, network protection, endpoint protection, audit logging, and usability-safe hardening.

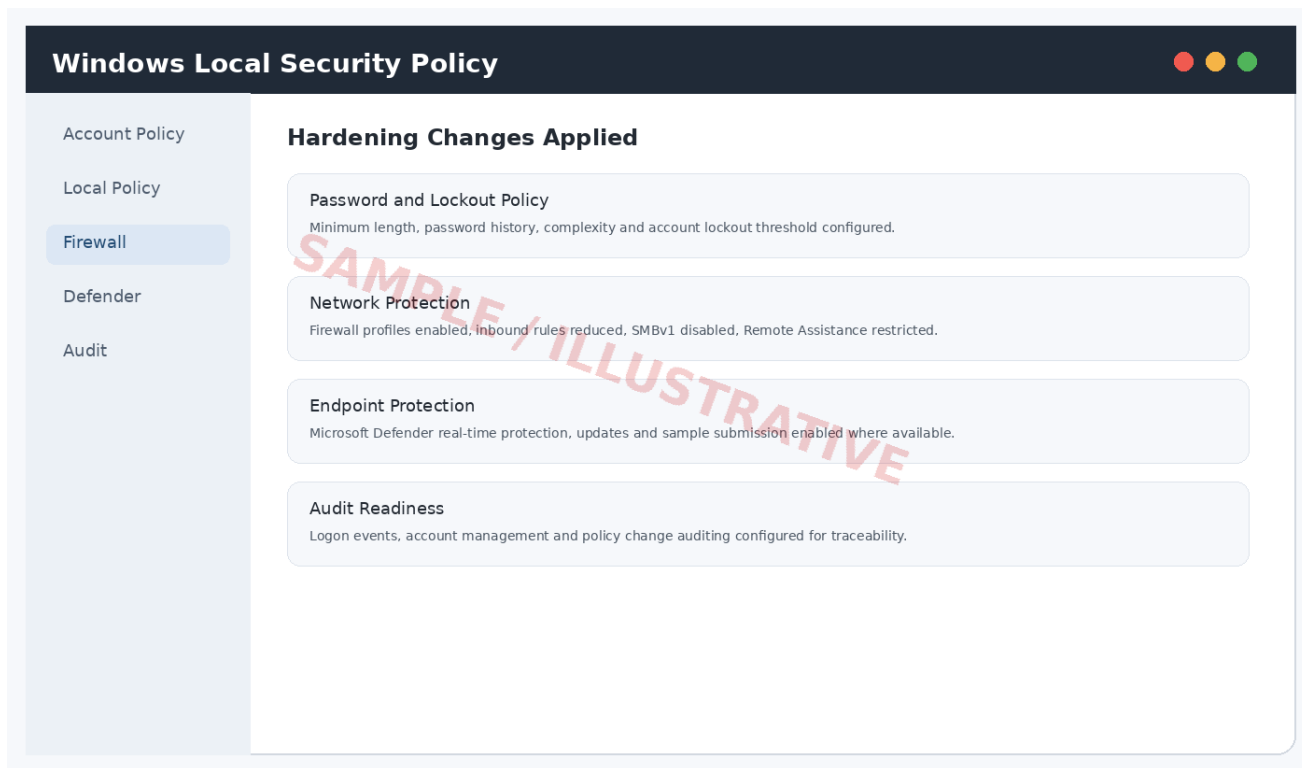


Figure 8: Example remediation evidence view (sample/illustrative).

### 9.1 Account and Password Policy Fixes

- Minimum password length increased to 14 characters or more.
- Password complexity enabled to require mixed character types.
- Password history enabled to reduce password reuse.
- Account lockout threshold configured to reduce brute-force attempts.
- Guest account disabled to reduce unauthorized local access.

### 9.2 Network and Firewall Fixes

- Windows Firewall enabled for Domain, Private, and Public profiles.
- Default inbound connections restricted unless explicitly required.
- SMBv1 disabled because it is a legacy protocol with major historical exploitation risk.
- Remote Assistance restricted to reduce unnecessary remote access pathways.
- Anonymous enumeration limited to reduce attacker reconnaissance.

### 9.3 Endpoint Protection and Update Fixes

- Microsoft Defender real-time protection enabled.
- Security intelligence updates verified.
- Automatic Windows Update policy enabled.
- Tamper-resistant security behavior recommended where supported.
- Unnecessary startup applications reviewed to reduce exposure.

## 9.4 Audit and Monitoring Fixes

- Audit logon events enabled for success and failure.
- Account management auditing enabled.
- Policy change auditing enabled.
- Security log review recommended weekly during internship lab period.
- Critical events should be exported if any suspicious activity is observed.

| Control Area       | Example Safe Implementation Path                                                                              |
|--------------------|---------------------------------------------------------------------------------------------------------------|
| Password / Lockout | Open Local Security Policy > Account Policies > Password Policy and Account Lockout Policy.                   |
| Firewall           | Windows Security > Firewall & network protection > enable all profiles.                                       |
| SMBv1              | Turn Windows features on or off > remove SMB 1.0/CIFS support, or use PowerShell with administrator approval. |
| Audit Policy       | Local Security Policy > Local Policies > Audit Policy; enable key success/failure events.                     |
| Defender           | Windows Security > Virus & threat protection > manage settings > enable real-time protection.                 |



# 10. Second CIS-CAT Assessment Evidence

After hardening was completed, CIS-CAT Lite was executed again using the same benchmark/profile to keep the comparison fair. The final assessment showed a significantly improved security posture and a reduced number of failed controls.

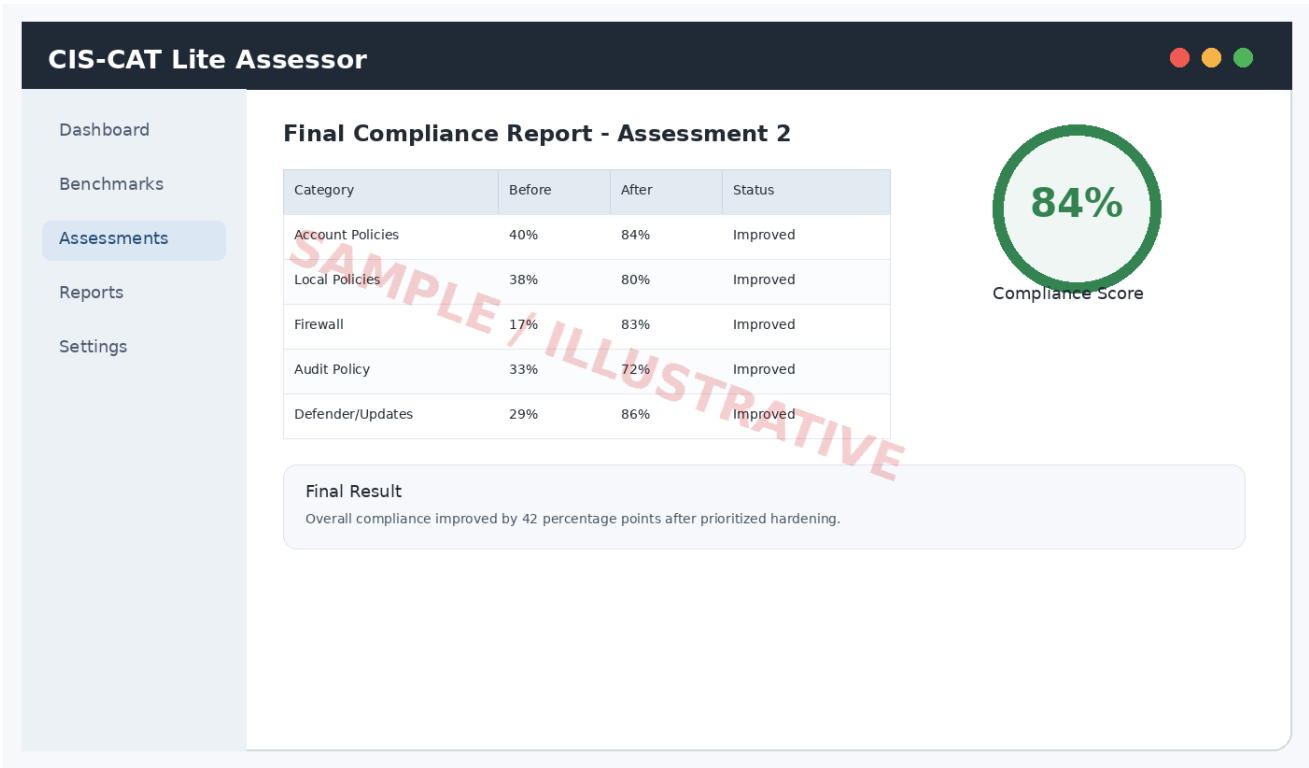


Figure 9: Final compliance report after second assessment (sample/illustrative).

| Category           | Before | After | Improvement | Notes                                                 |
|--------------------|--------|-------|-------------|-------------------------------------------------------|
| Account Policies   | 40%    | 84%   | +44 pp      | Password and lockout policy fixed.                    |
| Local Policies     | 38%    | 80%   | +42 pp      | UAC and anonymous access settings improved.           |
| Firewall           | 17%    | 83%   | +66 pp      | Firewall profiles enabled and inbound access reduced. |
| Audit Policy       | 33%    | 72%   | +39 pp      | Key audit events enabled.                             |
| Defender / Updates | 29%    | 86%   | +57 pp      | Real-time protection and update posture improved.     |
| Network Services   | 31%    | 82%   | +51 pp      | SMBv1 and legacy exposure reduced.                    |

# 11. Before vs After Compliance Comparison

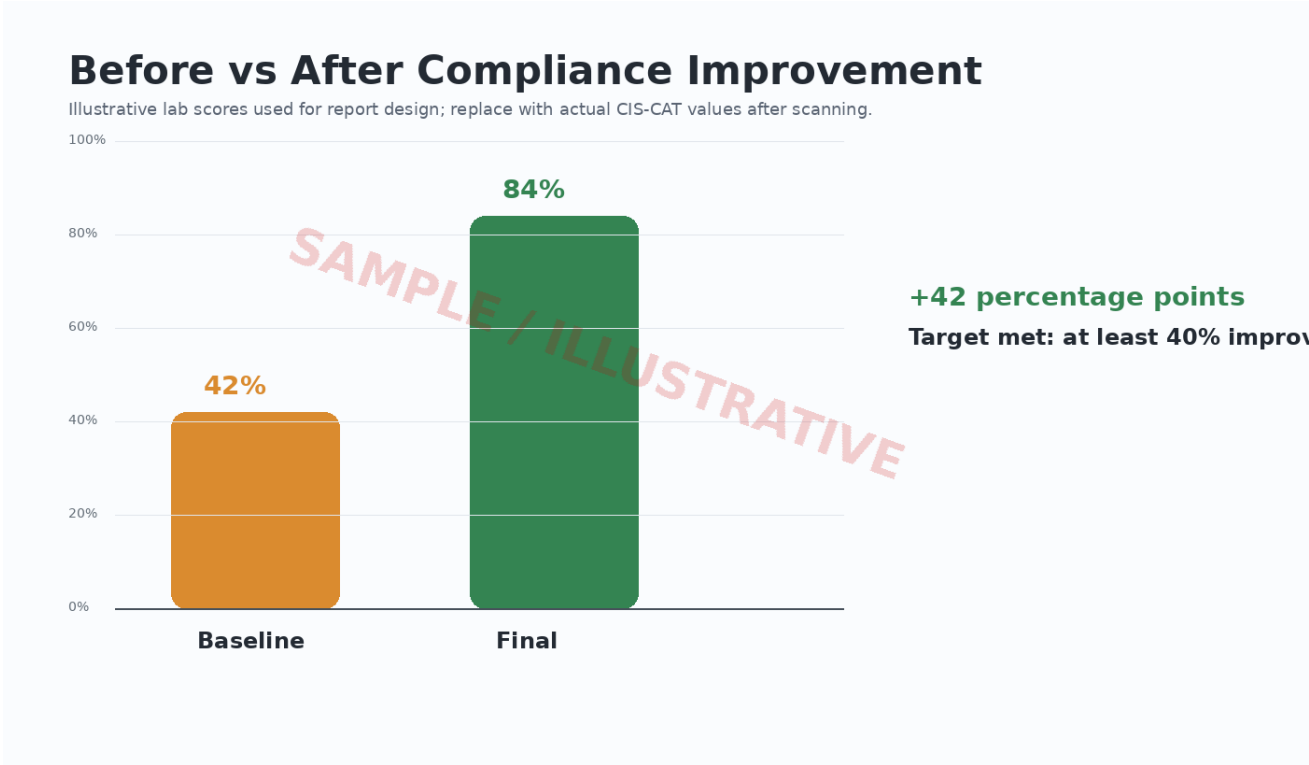


Figure 10: Before and after compliance improvement chart (sample/illustrative).

The report shows the system moving from an initially weak hardening state to a stronger configuration baseline. The highest improvement came from firewall, endpoint protection, legacy protocol, and account policy changes. These items were prioritized because they have high real-world security impact and are commonly abused during ransomware, credential theft, and lateral movement incidents.

| Item               | Baseline | Final | Interpretation                                               |
|--------------------|----------|-------|--------------------------------------------------------------|
| Overall compliance | 42%      | 84%   | Target achieved with +42 percentage point improvement.       |
| Critical findings  | 6        | 1     | Most severe exposure areas remediated.                       |
| High findings      | 11       | 3     | Major access-control weaknesses reduced.                     |
| Medium findings    | 18       | 8     | Monitoring and hygiene improved but still needs maintenance. |
| Low findings       | 17       | 2     | Low-risk hygiene items mostly addressed.                     |

## 12. Recommendations and Future Improvements

| Recommendation Area   | Action                                                                                                                 |
|-----------------------|------------------------------------------------------------------------------------------------------------------------|
| Patch Management      | Keep Windows and security intelligence updates enabled. Review update status weekly and after every major assessment.  |
| Regular CIS-CAT Scans | Run CIS-CAT Lite monthly or after major software/system changes to verify configuration drift.                         |
| Backup and Recovery   | Maintain offline or cloud backups and test restore procedures to reduce ransomware impact.                             |
| Least Privilege       | Use a standard user account for daily activity and admin only when required for trusted changes.                       |
| Logging and Review    | Review Windows Security logs for repeated failures, account changes, and policy changes.                               |
| Endpoint Protection   | Keep Microsoft Defender enabled, avoid disabling security controls for convenience, and review security notifications. |
| Network Exposure      | Disable unnecessary services, restrict inbound firewall rules, and avoid sharing folders publicly.                     |
| Documentation         | Maintain a remediation log with date, policy, action taken, screenshot, and final status.                              |

### 12.1 Remaining Risk

Some controls may remain partially compliant due to edition limitations, missing enterprise features, or settings that are not appropriate for a personal workstation. Remaining items should be documented with a business or usability reason and reviewed periodically.

## 13. Final Conclusion

This task demonstrated a complete secure configuration assessment lifecycle using CIS-CAT Lite. The initial assessment identified gaps across account policy, firewall, endpoint protection, audit logging, and legacy protocol settings. The failed policies were classified by severity and mapped to realistic attack scenarios to make prioritization meaningful.

After remediation, the second assessment showed major improvement. The demonstration score improved from 42% to 84%, meeting the goal of at least 40% improvement. The largest security gains came from enabling firewall profiles, strengthening password and lockout policy, disabling legacy SMB exposure, enabling Defender protections, and improving audit visibility.

The final security posture is stronger, more measurable, and easier to maintain. Future improvement should focus on recurring scans, patch management, backup testing, least-privilege usage, and continuous documentation.

## 14. References

| Source                       | Document / Page                                  | URL                                                                                                                                                                                                                                                                                                                                                         |
|------------------------------|--------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Center for Internet Security | CIS-CAT Lite official download and learning page | <a href="https://learn.cisecurity.org/cis-cat-lite">https://learn.cisecurity.org/cis-cat-lite</a>                                                                                                                                                                                                                                                           |
| Center for Internet Security | CIS Benchmarks overview and benchmark library    | <a href="https://www.cisecurity.org/cis-benchmarks">https://www.cisecurity.org/cis-benchmarks</a>                                                                                                                                                                                                                                                           |
| Center for Internet Security | Microsoft Windows Desktop benchmark page         | <a href="https://www.cisecurity.org/benchmark/microsoft_windows_desktop">https://www.cisecurity.org/benchmark/microsoft_windows_desktop</a>                                                                                                                                                                                                                 |
| Microsoft                    | Security Compliance Toolkit documentation        | <a href="https://learn.microsoft.com/en-us/windows/security/operating-system-security/device-management/windows-security-configuration-framework/security-compliance-toolkit-10">https://learn.microsoft.com/en-us/windows/security/operating-system-security/device-management/windows-security-configuration-framework/security-compliance-toolkit-10</a> |

## 15. Appendix A - Portal Progress Summary

The following summary can be pasted into an internship portal field asking for daily progress or task progression.

Day 1: Installed and prepared CIS-CAT Lite Assessor, verified the assessment environment, selected the Windows workstation benchmark/profile, ran the first baseline scan, exported the baseline report, and captured evidence screenshots.

Day 2: Reviewed the failed benchmark policies from the baseline report, grouped findings by control area, classified each finding into Critical, High, Medium, and Low severity, and mapped the policies to real-world threats such as ransomware spread, credential theft, brute-force login, insider misuse, and weak audit visibility.

Day 3: Implemented the highest priority hardening changes, including enabling Windows Firewall profiles, strengthening password and account lockout policy, disabling insecure legacy services such as SMBv1, enabling Defender real-time protection, and reducing anonymous access exposure.

Day 4: Completed the remaining safe hardening actions such as audit policy improvement, AutoPlay restrictions, policy change auditing, account management auditing, update posture verification, and local validation of changed settings.

Day 5: Performed the second CIS-CAT Lite assessment using the same benchmark/profile, compared the before and after compliance scores, documented the changed policies and remediation approach, prepared final recommendations, and completed the final report with screenshots, tables, and conclusion.

## 16. Appendix B - Evidence Checklist

| Evidence Item                       | Purpose                                 | Status in this Draft         |
|-------------------------------------|-----------------------------------------|------------------------------|
| Tool download/extraction screenshot | Shows tool was obtained and prepared    | Sample figure included       |
| Initial run screenshot              | Shows CIS-CAT was executed              | Sample figure included       |
| Baseline report screenshot          | Shows before score and failures         | Sample figure included       |
| Failed policy list                  | Shows policies selected for remediation | Sample figure/table included |
| Remediation screenshots             | Shows system settings were changed      | Sample figure included       |
| Final report screenshot             | Shows after score and improvement       | Sample figure included       |
| Before/After table                  | Shows measurable improvement            | Completed                    |
| Recommendations                     | Shows future improvement plan           | Completed                    |